

Nonfunctional Requirements

Section Owner: Security Lead

Project: Organizational Inventory Management/Checkout Service

Stack: MERN (MongoDB, Express, React, Node.js)

1. Overview

This section defines the nonfunctional requirements (NFRs) for the inventory management/checkout system, covering security, reliability, scalability, performance, compatibility, maintainability, usability, and compliance. These requirements apply across all organizational tenants using the platform and constrain how the system must behave, as distinct from the functional requirements that define what it does.

2. Security Requirements

2.1 Authentication & Authorization

ID	Requirement	Priority
SR-1	The system shall enforce role-based access control (RBAC) with, at minimum, Member, Approver, and Org Admin roles. Permissions shall be enforced server-side on every request, not solely via UI restrictions.	Must
SR-2	The system shall isolate data between organizations (multi-tenancy) such that no user can view or modify another organization's inventory, requests, or logs, including via direct API calls.	Must
SR-3	Passwords shall be hashed using a modern algorithm (bcrypt or argon2) with a per-user salt. Plaintext passwords shall never be logged or stored.	Must
SR-4	Sessions shall use short-lived JWTs with refresh tokens, secure/httpOnly cookies, and automatic expiration after a period of inactivity (e.g., 30 minutes).	Must

2.2 Data & Transport Security

ID	Requirement	Priority
SR-5	All client-server communication shall be encrypted via TLS (HTTPS only; no fallback to HTTP).	Must
SR-6	All user input shall be validated and sanitized server-side to prevent NoSQL injection (e.g., MongoDB operator injection via \$gt, \$where) and stored XSS in fields such as asset names and notes.	Must
SR-7	Sensitive fields, if any PII beyond names/emails is stored, shall be encrypted at rest.	Should

2.3 Audit Log Integrity

ID	Requirement	Priority
SR-8	Audit logs shall be append-only/immutable at the application layer. No role, including Org Admin, shall be able to edit or delete historical log entries through the UI or API.	Must
SR-9	Every state-changing action (request, approval, denial, checkout, return, inventory edit) shall be logged with actor identity, timestamp, and before/after state.	Must

ID	Requirement	Priority
SR-10	Audit logs shall support non-repudiation, providing sufficient detail to reconstruct who performed an action and when, for dispute resolution (e.g., a member disputing that a return was recorded).	Must

2.4 Operational Security

ID	Requirement	Priority
SR-11	API secrets, database credentials, and JWT signing keys shall be stored in environment variables or a secrets manager, never committed to source control.	Must
SR-12	Authentication endpoints shall be rate-limited to mitigate brute-force login attempts.	Should
SR-13	Third-party dependencies shall be scanned for known vulnerabilities (e.g., npm audit) as part of the CI pipeline.	Should
SR-14	CORS policy shall restrict API access to known, whitelisted frontend origins.	Must

3. Reliability & Availability

ID	Requirement	Priority
NFR-1	The system shall target 99% uptime during an organization's active business hours.	Should
NFR-2	The system shall handle unexpected errors (failed database writes, network interruptions) gracefully without corrupting inventory state — e.g., a failed checkout shall never leave an asset in an ambiguous or partially-checked-out state.	Must
NFR-3	Database backups shall run on a regular schedule (e.g., daily) with a documented recovery process.	Should

4. Scalability

ID	Requirement	Priority
NFR-4	The system shall support multiple organizations operating concurrently without performance degradation, with the data model designed to scale horizontally (e.g., indexing/sharding by organization ID).	Should
NFR-5	The system shall remain responsive with at least [TBD — team to set, e.g., 50–100] concurrent users per organization.	Should

5. Performance

ID	Requirement	Priority
NFR-6	Standard API responses (inventory list, request status) shall return within 500ms under normal load.	Should
NFR-7	Page loads shall complete within 2–3 seconds on a typical broadband connection.	Should

6. Compatibility

ID	Requirement	Priority
NFR-8	The web application shall function correctly on the latest two versions of major browsers (Chrome, Firefox, Safari, Edge).	Must

ID	Requirement	Priority
NFR-9	The UI shall be responsive and usable on both desktop and tablet/mobile viewport sizes.	Should

7. Maintainability

ID	Requirement	Priority
NFR-10	Code shall follow a consistent style guide (e.g., ESLint/Prettier configuration) enforced via CI.	Should
NFR-11	Core business logic (approval workflows, checkout state transitions) shall have automated test coverage.	Should

8. Usability & Accessibility

ID	Requirement	Priority
NFR-12	The interface shall meet WCAG 2.1 AA accessibility guidelines where practical (contrast, keyboard navigation, alt text).	Should
NFR-13	Core workflows (request an asset, approve a request, check out/return an asset) shall be completable by a new user without external documentation.	Should

9. Compliance

ID	Requirement	Priority
NFR-14	If deployed for educational institutions handling student data, data handling practices should be evaluated against FERPA. Regardless of sector, the system should follow reasonable data-minimization practices.	Should